

Agile Security Issues: An Empirical Study

Ahmed Alnatheer

ECS, University of Southampton

Southampton, SO17 1BJ, UK

aaa1v09@ecs.soton.ac.uk

Andrew M. Gravell

ECS, University of Southampton

Southampton, SO17 1BJ, UK

amg@ecs.soton.ac.uk

David Argles

ECS, University of Southampton

Southampton, SO17 1BJ, UK

da@ecs.soton.ac.uk

Abstract

In this poster we introduce an ongoing empirical study on the effects of using predominant security issues along with agile methodologies. As part of this empirical study, current security issues related to and applicable to agile methodologies such as Scrum, XP, and FDD and their effects are discussed. The purpose of this poster is to present an introduction to this ongoing effort and to present our analysis of the issues which are important factors in our forthcoming results which underscores the gap in the literature. The analysis will include experiments, semi-structured interviews, and surveys that seek to gather relevant objective and subjective information about projects and experiments in order to arrive at a consensus on which issues need to be included or emphasized as part of agile to provide adequate security assurance.

Categories and Subject Descriptors

K.6.5 [Management of Computing and Information Systems]: Security and protection. D.2.4 [Software Engineering]: Software/program verification. K.6.3 [Software Engineering]: Software management – *software process*.

General Terms

Measurement, Design, Reliability, Experimentation, Security, Human Factors, Verification.

1. Research Questions

1. Is there a way to seamlessly combine security and agility, or more importantly, how can we evaluate the suitability of security mechanisms for use in agile?
2. Is extending agile practices for better security a necessary step from the stakeholder point of view?
3. Do most security issues stem from software vulnerabilities?
4. Should the customer dictate the level of required security for a given project?
5. What are the effects of knowledge diffusion on a given agile project in terms of security awareness of its members?
6. How beneficial is dedicated security iteration through monitoring a set of metrics to gauge its effectiveness?
7. What is the best prioritization mechanism to measure the level of risk for a given security requirement?
8. Do the testing and verification tools used by agile teams provide adequate security assurance for the software in addition to quality assurance?

9. Does the lack of documentation in agile projects contribute to less secure software?

2. Related Work

From the security engineering perspective, research suggests that there is a clash or disparity [1] between established security methodologies and the ideas and methodologies proposed by the agile advocates [2]. Security experts often criticize agile for having a fundamental lack of an inherent security mechanism to produce secure software but fail to acknowledge that their approach is heavily focused on documentation and practices which hinders the agile process in many ways if applied without modification. The current proponents of extending agile methodologies have not yet been able to prove why the current process cannot accommodate security practices as part of the established framework and why an amendment or extension is required in order for this to happen. There are a number of solutions proposed by both sides of the argument which suggest a set of compromises in order to bring the two methodologies closer to integration [2]. From this body of work, a set of ideas, issues, and hypotheses emerge that is the focus of this research to extract, analyze, and get empirical evidence for or against their adoption.

3. Analysis and Future Work

The data collection mechanism will be in the form of interviews, questionnaires, surveys, and experiments to get appropriate qualitative and quantitative data for the issues that were discussed earlier. We have also developed a more sophisticated type of survey that optimizes the questions based upon respondent's role and their responses to earlier questions in the survey which is designed to get more accurate and specific information than was previously possible through using classical survey methods. Both objective and subjective data will be gathered in order to have a more appropriate set of measurements available for analysis. Comprehensive literature review and investigation on the topics of security and agile is already completed and a number of outstanding issues and hypotheses have been identified which will be presented later. These efforts are currently under way and more data still needs to be collected and will be presented in follow-up papers on the same topic.

4. References

- [1] Viega, J., McGraw, G. 2001. Building secure software: how to avoid security problems the right way, Addison-Wesley Longman Publishing Co., Inc., Boston, MA, 2001
- [2] Beznosov, K. and Kruchten, P. 2005. Towards agile security assurance. *Proceedings of the 2004 workshop on New security paradigms - NSPW '04*, (2005), 47.